

SOC 2 Type 2

Compliance Tracker

NexOrder — NexGen Innovations. Tick each control as it lands and date it. This file is the record: open it in a PDF reader, fill it in, and save. Findings are numbered as they appear in the readiness audit.

AUDIT DATE	COMMIT	FINDINGS OPEN	POLICY DOCS
14 Aug 2026	6596b44	19	0 of 14

Programme dates

Auditor selected	
Readiness assessment / Type 1 complete	
Observation window opens	
Observation window closes	
Report issued	

Accepted risks — management sign-off

Both are deliberate decisions, not oversights. An auditor will test them, so they belong in the risk register signed and dated.

- ☐ Change approval — CI cannot block a merge (GitHub Free / private repo) and deploys run from a laptop holding client credentials. Compensating control: the release-tag gate.
- ☐ OpenAI as an unagreed subprocessor — customer PO documents and the customer list are sent with no DPA and no zero-retention flag. Mitigation: disclosure via subprocessor register.

SIGNED

Remediation checklist

Phases 4 and 5 are writing rather than code, so they run in parallel with 1–3. Nothing in Phase 6 starts until everything before it is operating.

PHASE 0

Verify live exposure

OWNER

TARGET

Hours. Do before anything else.

Confirm VITE_SHOW_DEMO_LOGINS=false on the Amadiya Vercel project

VERIFIED 2026-08-14 – live bundle clean, none of 6 credential patterns present

DONE

Confirm no seeded accounts survive on Amadiya; rotate anything that does

Password123! was in a public bundle – treat as compromised

Build-time assertion: a tenant build FAILS if the flag is not false

vite.config.ts beside the module-flag defines + scripts/check-csp.mjs pattern

Phase 0 evidence / notes

PHASE 1

Critical technical gaps

OWNER

TARGET

Findings 2, 3, 4, 5. One to two weeks. Rehearse on dev first.

1.1 Private media buckets · finding 2 · PROVEN LIVE

DONE

Migration: public=false on signatures, visit-photos, avatars

new 00106_private_media_buckets.sql

Drop public_read_* policies; add staff / own-scope SELECT

built on public.user_is_staff() from 00105:89-109

Add create-media-url edge function, audited on every issuance

follow create-po-document-url/index.ts pattern

Update render paths: visit photos, POD signatures, avatars

components/visits/*, order & dispatch surfaces, avatar_url consumers

Check the storage proxy does not assume public objects

vercel.ts:65-83

Verify: unauthenticated fetch 403, signed URL 200, audit row written

Write incident record #1 — exposure, impact, notification decision

exercising the IR process once is itself audit evidence

1.2 Offboarding path · finding 3

DONE

Migration: is_active, deactivated_at, deactivated_by on profiles

profiles has no such column today – 00001:85-100

deactivate-user edge function: Admin-only, rate-limited, zod, audited, revokes sessions

Enforce is_active in requireAuth

_shared/auth.ts – it already fetches the profile row

Enforce in AuthGate

components/auth/AuthGate.tsx:36-38

Wire the dead onDeleteUser handler

components/AppShell.tsx:1167-1169 – currently a toast that does nothing

Verify: live session dies on next request, re-login refused, audit row exists

1.3 invite-user · findings 4, 17

DONE

Add logAuditEvent — account creation is currently untraceable

follow mutate-profile/index.ts:104-107

Add a zod schema: email, name max length, avatarUrl as URL
replaces String(body.x ?? '') coercion and a naive regex

1.4 MFA for staff roles · finding 5

DONE

Enable TOTP in apply-auth-config.mjs buildDesired()
keeps it config-as-code with the existing --check drift mode

TOTP enrolment UI, mounted post-login for staff without a factor
components/auth/

Require AAL2 for the five staff roles in requireAuth and AuthGate

Longer trusted-device window for Warehouse (shared floor devices)

Audit enrol, unenrol and failed-challenge events

Verify: Admin forced to AAL2; customer login unaffected

Phase 1 evidence / notes

PHASE 2	OWNER	TARGET
Retention and audit integrity		
<i>Findings 6, 7, 8. One to two weeks. Rehearse purges with BEGIN...ROLLBACK.</i>		
		DONE
Write docs/compliance/data-retention-policy.md Australian statutory defaults		
Purge job: orders, order_items, invoices — 7 years ATO record-keeping		
Purge job: audit_events — 2 years		
Purge job: inbound_messages, pending_pos, po-archive bucket — 12 months		
Purge job: po_extraction_audit — 180 days		
Purge job: client_errors — 90 days		
Rework the ON DELETE RESTRICT chain so inbound messages can age out 00018_po_inbox.sql:109,148 — currently makes erasure structurally impossible		
Purge storage objects alongside rows — the bucket has no DB cascade		
REVOKE UPDATE, DELETE on audit_events + append-only trigger follow 00059_health_monitoring.sql:54		
Stop silently swallowing audit write failures _shared/audit.ts:37-42 — console.warn then return		
Add ip_address, user_agent, request_id to audit_events clientIp() already exists at _shared/rateLimit.ts:121		
Extend AuditAction: read, export, login, logout, login_failed		
Surface auth.audit_log_entries into the audit viewer		
Close the 23 unaudited functions place-order, update-order-status, create-*-document-url, both OAuth callbacks first		
Fix the restore path destroying the audit trail supabase/ops/import-demo.mjs:47-56 SKIP map		
Verify: DELETE FROM audit_events as service_role is refused		
Phase 2 evidence / notes		

PHASE 3	OWNER	TARGET
Availability		
<i>Findings 9, 10. One week. The restore drill must actually run.</i>		
		DONE
Make ALERT_EMAIL required so secrets:check fails without it supabase/ops/secrets.mjs:89 — currently OPTIONAL_FROM_FILE		
Add an alert channel outside the database failure domain health/index.ts writes alerts to the DB whose outage it reports		
Add cron-freshness monitoring po-poll-inbox can stop while health still reports ok		
Point an external uptime monitor at the unauthenticated GET /health tier		
Configure escalation and a status page		
Run a real restore drill on dev, timed the measured number IS the RTO		
Write docs/runbooks/RUNBOOK-restore.md from what actually happened prescribed at PRODUCTION-LAUNCH-PLAN.md:389, never written		
Record demonstrated RTO and RPO daily backups, 7-day retention, no PITR !ð RPO up to 24h		

Write docs/compliance/business-continuity-plan.md
incl. Supabase and Vercel outage playbooks, key-person risk

Record git identity in deployments.deployer, not os.userInfo()
scripts/deploy.mjs:294

Add the clean-tree / tag / ancestry gate to migrate.mjs
it has NONE today – schema changes reach production from any tree state

Phase 3 evidence / notes

PHASE 4	OWNER	TARGET
Confidentiality and vendors		
Findings 14–19. One week. Policy and code together.		
		DONE
docs/compliance/data-classification.md + PII data map		
docs/compliance/subprocessors.md OpenAI, Supabase, Vercel, Google, Microsoft, Resend, GitHub		
Publish a privacy policy also currently blocking Google OAuth verification		
Publish terms of service		
Draft customer commitments — MSA, SLA, DPA none exist; SOC 2 audits you against your own stated promises		
OpenAI: send top-N candidates, not the entire customer list _shared/poInbox/aliasResolver.ts:367-369		
OpenAI: set store:false and org / project scoping headers _shared/poInbox/openai.ts:169-180		
Enforce CSP and add a report-uri vercel.ts:98 – Report-Only with no endpoint collects nothing		
Add password complexity, logout and an absolute session timeout supabase/apply-auth-config.mjs		
Alert when the rate limiter falls open to in-memory _shared/rateLimit.ts:65-74		
Add gitleaks and CodeQL to CI .github/workflows/ci.yml		
Document a PO_ENCRYPTION_KEY rotation procedure _shared/poInbox/encryption.ts:12-16 – no rotation capability today		

Phase 4 evidence / notes

PHASE 5	OWNER	TARGET
Governance layer		
Finding 13. Two to three weeks — the long pole, and entirely greenfield.		
		ADOPTED
Information Security Policy		
Access Control Policy		
Incident Response Plan		
Business Continuity & Disaster Recovery Plan		
Change Management Policy		
Risk Assessment + risk register		
Vendor / Third-Party Management Policy		
Data Retention & Disposal Policy		
Secure SDLC Policy		
Encryption & Key Management Policy		
Asset Inventory		
Acceptable Use Policy		
Security Awareness Training Policy		
System Description with TSC mapping		

Operational artefacts

DONE

Employee onboarding checklist
for the 2-5 non-technical staff

☐

Employee offboarding checklist
must reference the Phase 1.2 deactivate-user path

☐

Incident register — opened, starting with record #1 from Phase 1.1

☐

Access register: who holds which credential, and rotation dates

☐

Phase 5 evidence / notes

PHASE 6	OWNER		TARGET
Observation window			
Three to six months. Opens only once Phases 0–5 are operating.			
			DONE
Select an auditor			
Complete a readiness assessment / Type 1			
Write docs/compliance/evidence-calendar.md			
manual collection was the chosen approach – the cadence has to be written down			
Observation window opened			
Evidence pack assembled and handed to the auditor			

Recurring evidence

This is what a Type 2 actually samples — controls operating repeatedly over time, not controls that exist once. Three --check modes you already have (auth:config:check, secrets:check, apply-auth-config --check) are continuous control monitoring; their dated output is the evidence.

Quarterly

		DATE
Q1 — user access review: roster exported, reviewed, signed, dated		
Q2 — user access review		
Q3 — user access review		
Q4 — user access review		
Q1 — risk register reviewed		
Q2 — risk register reviewed		
Q3 — risk register reviewed		
Q4 — risk register reviewed		

Monthly

		DATE
auth:config:check output filed to the evidence folder		
secrets:check output filed to the evidence folder		
Backup verified present and restorable		

Annual

		DATE
Security awareness training completed by all staff, with records		
Restore drill re-run and RTO / RPO re-measured		
Vendor review: subprocessor list re-confirmed, SOC 2 reports collected		
Policy set reviewed and re-approved		

Incidents raised this period (date, summary, resolution)	

Findings reference

Numbering matches the readiness audit. Severity reflects the position at 14 Aug 2026.

CLOSED

- 02** Customer signatures, premises photos and staff avatars world-readable — PROVEN
00004:9,11,18-28 · 00024:15,20-26
- 03** No offboarding path exists — Delete User is a no-op, no is_active column
AppShell.tsx:1167-1169
- 04** invite-user writes no audit event — account creation untraceable
invite-user/index.ts
- 05** No MFA anywhere, including Admin
grep mfa|totp|aal2 !' zero
- 01** Demo Admin credentials — checked, clean; needs a build-time assertion
LoginPage.tsx:42-56
- 06** Nothing is ever deleted — no PII retention or purge of any kind
00018:109,148
- 07** Audit trail deletable, unretained, and discarded on restore
00012 · import-demo.mjs:47-56
- 08** Audit writes best-effort and swallowed; no IP, UA, auth or read events; 23/71 unaudited
_shared/audit.ts:37-42
- 09** Alerting dead by configuration; monitor sits inside its own failure domain
secrets.mjs:89 · health/index.ts:217-224
- 10** No tested restore, no RTO, no RPO, no PITR
PRODUCTION-LAUNCH-PLAN.md:389,425
- 11** No login lockout; no absolute session timebox (idle timeout is client-side only)
apply-auth-config.mjs · useIdleTimeout.ts:12
- 12** CSP is Report-Only with no report endpoint — zero XSS mitigation
vercel.ts:98
- 13** Zero policy documents of any kind — blocks a Type 2 report outright
docs/ inventory
- 14** Rate limiter fails open to per-isolate memory, unmonitored
_shared/rateLimit.ts:65-74
- 15** Customer banking details stored plaintext; no field-level encryption
horeca_payment_methods.details
- 16** PO_ENCRYPTION_KEY has no rotation capability
encryption.ts:12-16
- 17** 15 edge functions lack schema validation, incl. invite-user and place-order
zod in 56/71
- 18** No secrets scanning or SAST in CI; npm audit excludes the build chain
.github/workflows/ci.yml
- 19** app_settings still USING (true) — deliberate, needs a column split
00105:53-70
- 20** Admin is a single omnipotent role; no access review process
types.ts:2-9